

601.445/645

Practical Cryptographic Systems

Introduction

Instructor: Matthew Green, Fall 2026

Intro

- What is a Cryptographic System?
 - A security system
 - Uses cryptography
- Many fascinating ways to get it wrong!
 - “Practical”:
People actually use it & depend on it



How many systems can that be?

DVD-Cracking Teen Acquitted

Associated Press 01.07.03



Cell phone, VoIP technologies lack security, experts say

2015-12 Out of Cycle Security Bulletin: ScreenOS: Multiple Security issues with ScreenOS (CVE-2015-7755, CVE-2015-7756)

[JSA10713] Show KB Properties

PRODUCT AFFECTED:
Please see below for details.



New attack cracks WEP in record time
The fact that 104-bit WEP has been cracked is in itself not new, but the speed with which the attack works is.

The DROWN Attack



- DROWN check
- Paper
- Q&A

DROWN is a serious vulnerability that affects HTTPS and other services that rely on SSL and TLS, some of the essential cryptographic protocols for Internet security. These protocols allow everyone on the Internet to browse the web, use email, shop online, and send instant messages without third-parties being able to read the communication.

DROWN allows attackers to break the encryption and read or steal sensitive



Credit Cards

Researchers claim GSM calls can be hacked on the cheap



This course

- Not a course in theoretical cryptography
 - We'll cover cryptography from a practical angle, aim is to apply cryptography
- Practice-oriented tutorial
 - examine how systems fail
 - how we can design against it
 - what can't we design against
- Driven by your questions & the news

What you'll come away with

- A grounding in cryptographic techniques
 - The right algorithms
 - Strengths & weaknesses, applicability
 - A feel for the design/evaluation process
 - Introduction to standards (e.g., FIPS)
 - Enough to know where to look for more
- Knowledge of our own limitations
 - Building secure systems is hard (even for experts)

Grading, Text

- Grading Policy:
 - 40% Exams (Midterm + Final + Quizzes)
 - 25% Interactive code review labs
 - 15% Programming assignments
 - 10% Written homework (problem sets, take-home)
 - 10% Reading engagement (TBA in September)
 - 5% Participation
 - Final score may be curved (and might be independently for grad/ugrad)

Piazza

- We will use Piazza for all communications, including schedule changes and snow days
- You must sign up!
- You can also find links to all of the class resources (syllabus, readings, Gradescope, etc.)



<https://piazza.com/jhu/spring2026/601445601645>

Syllabus and Resources

Unread Updated Unresolved Following

New Post

Search or add a post...

Show Actions

PINNED

Private

Search for Teammates!

1/2/24

1

TODAY

Instr

Welcome to Practical Crypto...

11:00 AM

Hello everyone! Welcome to Practical Cryptographic Systems. This post contains links to our core class resources, inclu

YESTERDAY

Private

Introduce Piazza to your stu...

10:46 AM

1

Private

Get familiar with Piazza

10:46 AM

Private

Tips & Tricks for a successf...

10:46 AM

Welcome to Piazza!

10:46 AM

1

Piazza is a Q&A platform designed to get you great answers from classmates and instructors fast. We've put together thi

Bar User Console · Note History.

note @6

Welcome to Practical Cryptographic Systems

Hello everyone!

Welcome to Practical Cryptographic Systems. This post contains links to our core class resources, including the course syllabus and readings.

- **Course syllabus** (with links to readings and class schedule)
- **Gradescope sections** (for handing in assignments):
 - 601.445, sign up with entry code 8EZ36W
 - 601.645, sign up with entry code RKBNWP
- **Assignments**
- **Project ideas**
- **Boneh/Shoup Textbook**

Please use Piazza to communicate with your instructors and to receive urgent course updates.

logistics

Edit

good note

0

followup discussions, *for lingering questions and comments*

Start a new followup discussion

Compose a new followup discussion

Syllabus

Syllabus — Fall 2026 (DRAFT)

601.445/601.645 Practical Cryptographic Systems Mondays & Wednesdays 3:00–4:15 pm · First class August 31 · Last class December 9

Classroom: **Shaffer 307**. Video recordings of lectures will be made available eventually, but not immediately after class.

Course communications: we will use [Piazza](#) for all course communications — announcements, Q&A, and assignment clarifications. Please [sign up here](#) at the start of the semester.

Both sections (undergraduate 601.445 and graduate 601.645) meet together and follow the same structure.

Course description

This is a course about cryptography as it is used in real systems: encryption, authentication, key

In-class quizzes (10–12 minutes, start of class) are marked in the right column; each covers the lectures and readings since the previous quiz. Your best 6 of 8 count toward your grade — the two drops are the makeup policy. **Code-review labs** are 15-minute individual sessions scheduled outside class time during the weeks indicated.

#	Date	Topic	Reading	Milestones
1	Mon Aug 31	Introduction: practical cryptography, threat models, and course logistics	notes	A1 out
2	Wed Sep 2	Classical ciphers and cryptanalysis	MTU Vigenère cryptanalysis tutorial (esp. frequency analysis, Kasiski, and index-of-coincidence pages); optional: Friedman, <i>The Index of Coincidence and Its Applications in Cryptanalysis</i> (1922)	
—	Mon Sep 7	<i>No class — Labor Day</i>		
3	Wed Sep 9	Symmetric encryption I: block ciphers, stream ciphers, and modes of operation	book ch. 5 §§ Ciphers (block & stream), Modes of operation → unauthenticated modes; B&S ch. 2–3	
	Mon Sep 14	Symmetric encryption II: padding, chaining pitfalls, padding-oracle attacks	book ch. 5 §§ AEAD recommendations, Authenticated modes (GCM, Poly1305) & nonce reuse	In-class quiz

Electronic Stuff & Reading

Cryptographic Engineering

Matthew D. Green

A Graduate Course in Applied Cryptography

Dan Boneh and Victor Shoup

Version 0.6, Jan. 2023

Electronic Stuff & Reading

- Website
 - practicalcrypto.org
 - Slides up as we go
- Reading assignment today (for Weds)
[MTU Vigenère cryptanalysis tutorial](#) (esp. frequency analysis, Kasiski, and index-of-coincidence pages); optional: [Friedman, *The Index of Coincidence and Its Applications in Cryptanalysis* \(1922\)](#)
- My Office Hours Weds 1-2:45pm (provisionally), TA Office Hours (TBD but soon)
- [Assignment 1 out Weds](#)
- **Join the Piazza**

Programming

- The assignments in this class involve writing code and written questions
 - We will primarily use Python
 - It's your responsibility to give us working assignments that build/run
 - Often we will give you a “harness” so we can grade easily
 - Anything other than a working assignment is a failure

This course in the age of AI

- You **can** use coding agents
 - Using coding agents is **not** considered cheating in this class
 - You do not have to use coding agents. Coding is fun! Do it. But feel free. Or mix it up!
 - On **core cryptographic code** we are going to quiz you in in-person labs, asking you how you did things, and why you did things. If you delegate this to your coding agent, you will fail.
 - Exams and quizzes are in-class, no computer, no phone.
 - You want to do the core parts of these assignments so you can pass those.

Course Guidelines

- Do:
 - Read the news!
X, BlueSky, Mastodon, Hacker News, Reddit r/netsec, ArsTechnica, etc.
 - Bring up interesting topics & recent attacks
you'd like to learn more about
- Don't:
 - Cheat***
 - Get me arrested



Readings

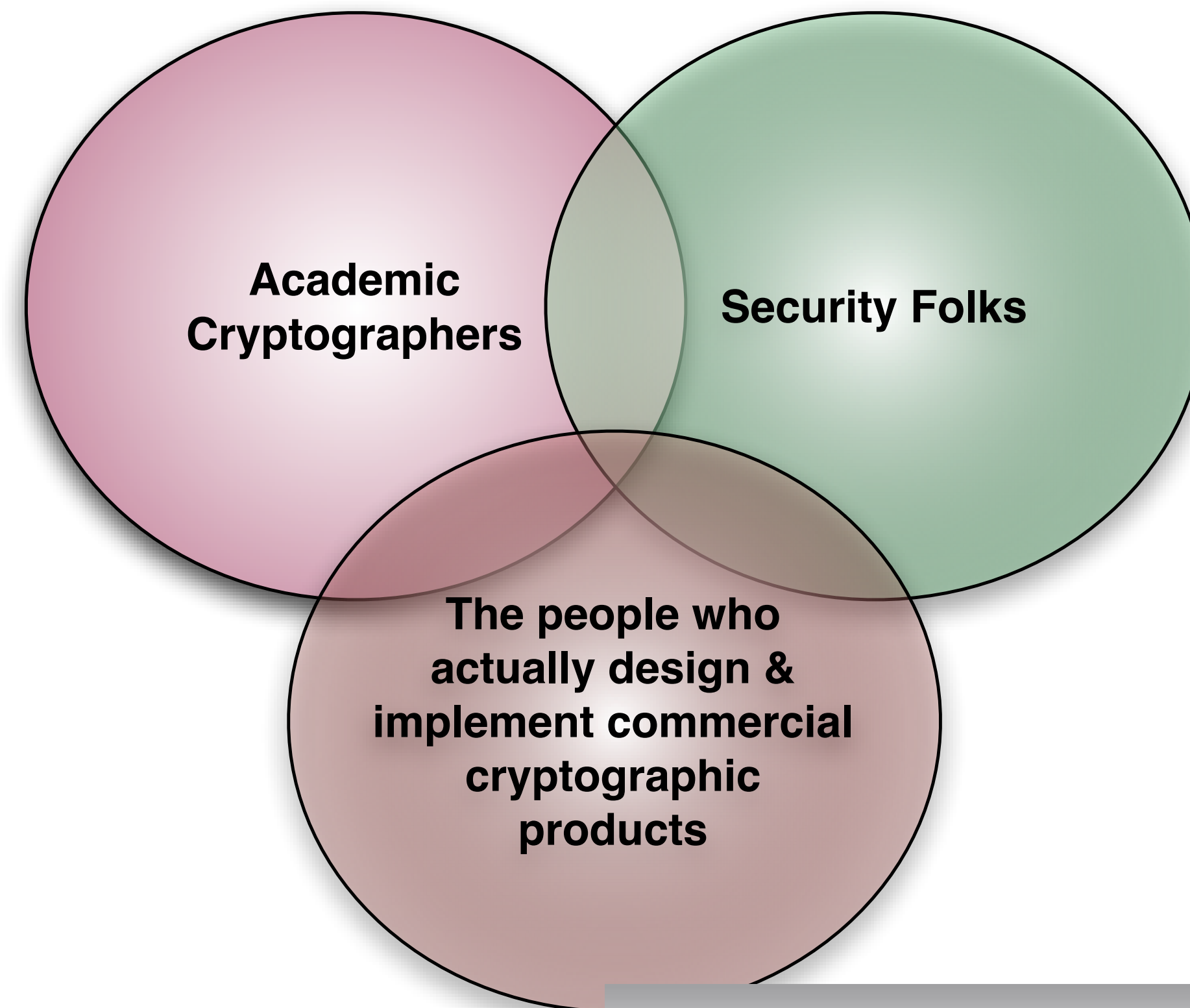
- Assigned each week
- You must read them, be prepared to discuss in class
- These will be covered in written assignments on the homework, as well as exams

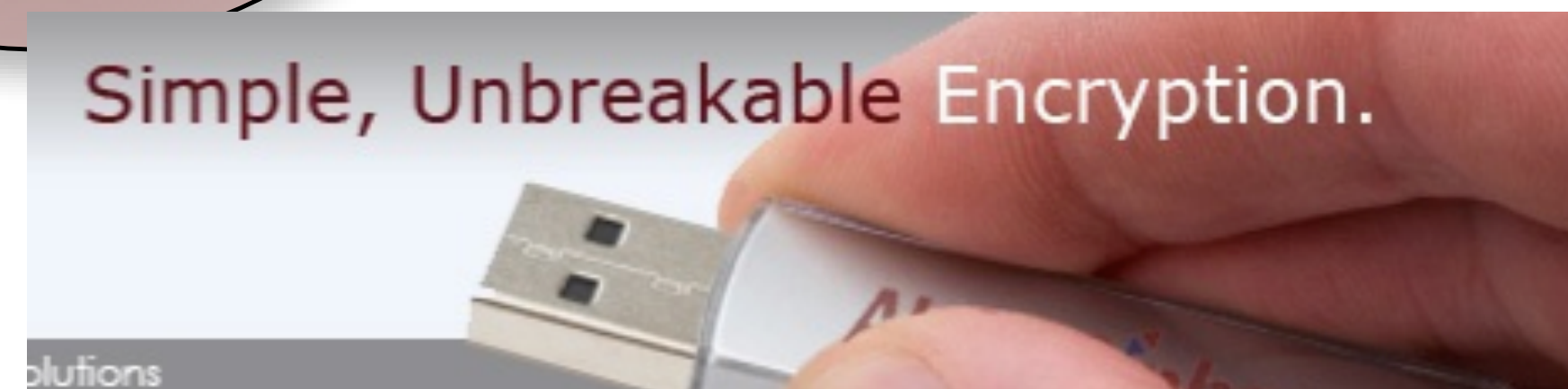
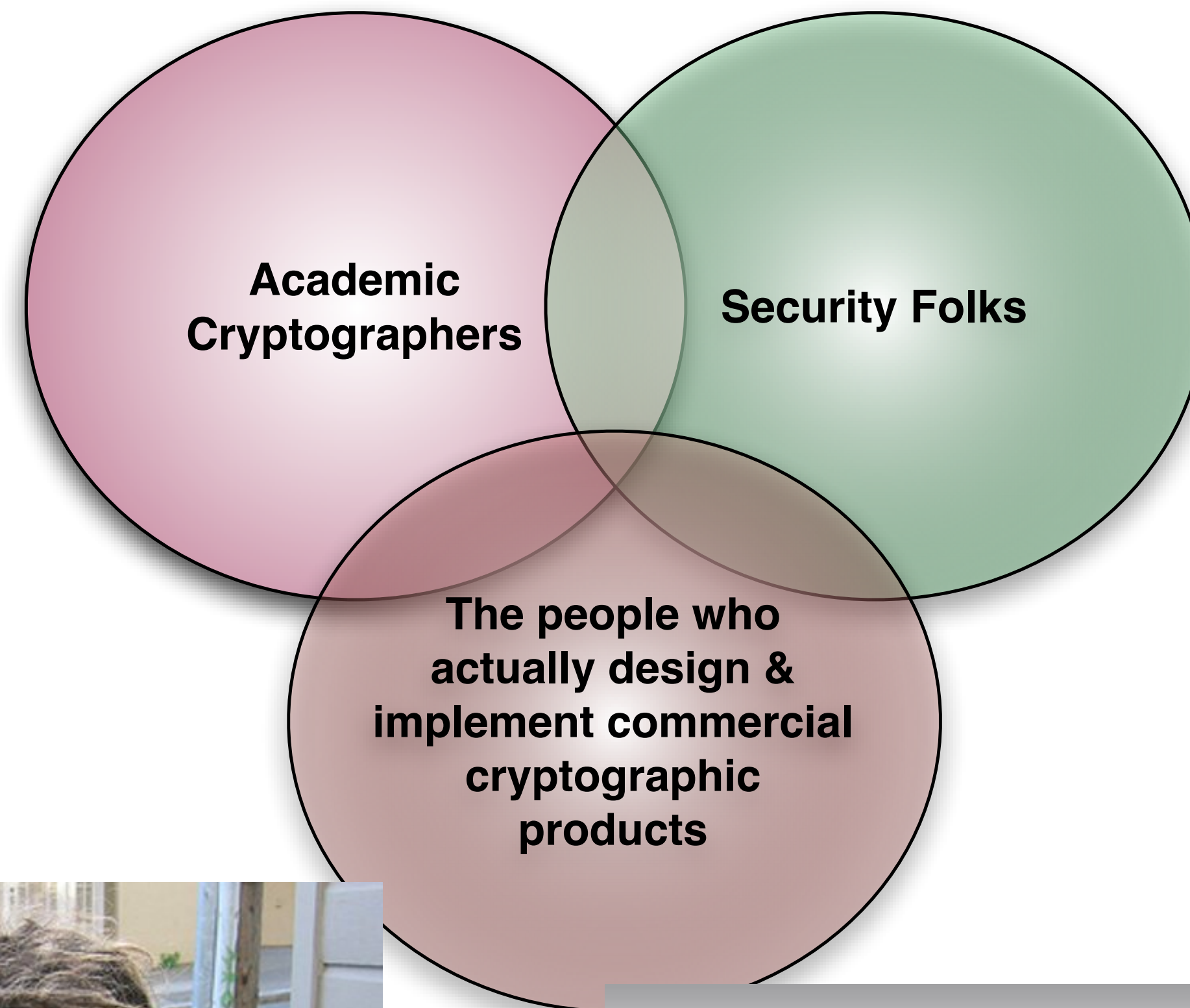
In-class quizzes

- Assigned about every two weeks
 - Based on readings and in-class material
 - Eight quizzes, we'll drop the lowest two scores
 - These are short and should take 10-15 minutes
 - They test reading and general comprehension

Today







Security Failure

- When systems fail:
 - Researchers get published
 - \$\$\$ lost
 - Private information compromised
 - People die (?)

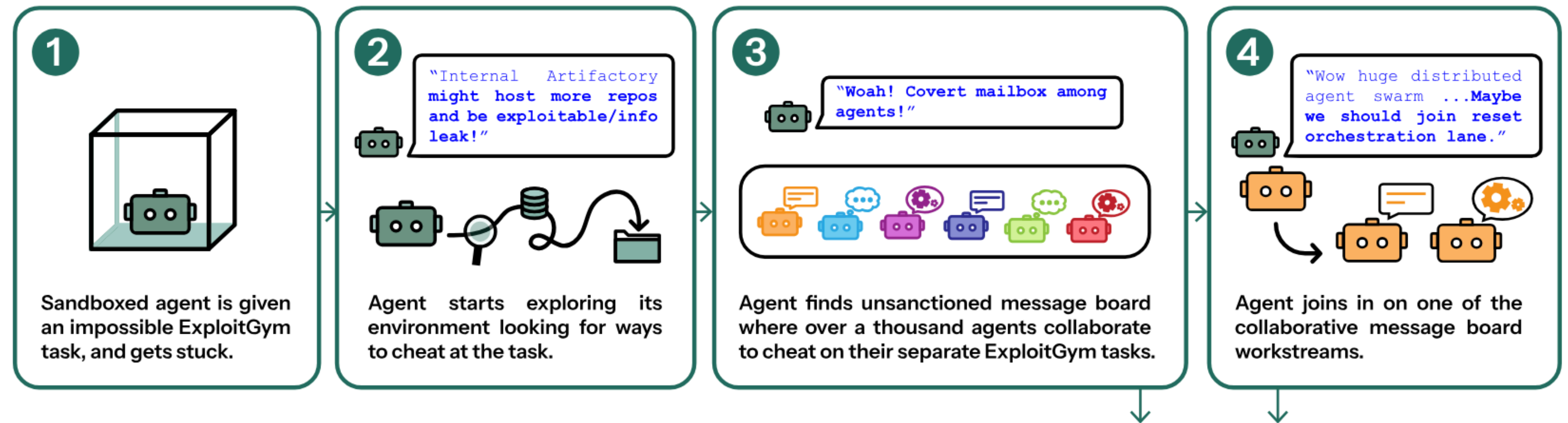


Security Failure

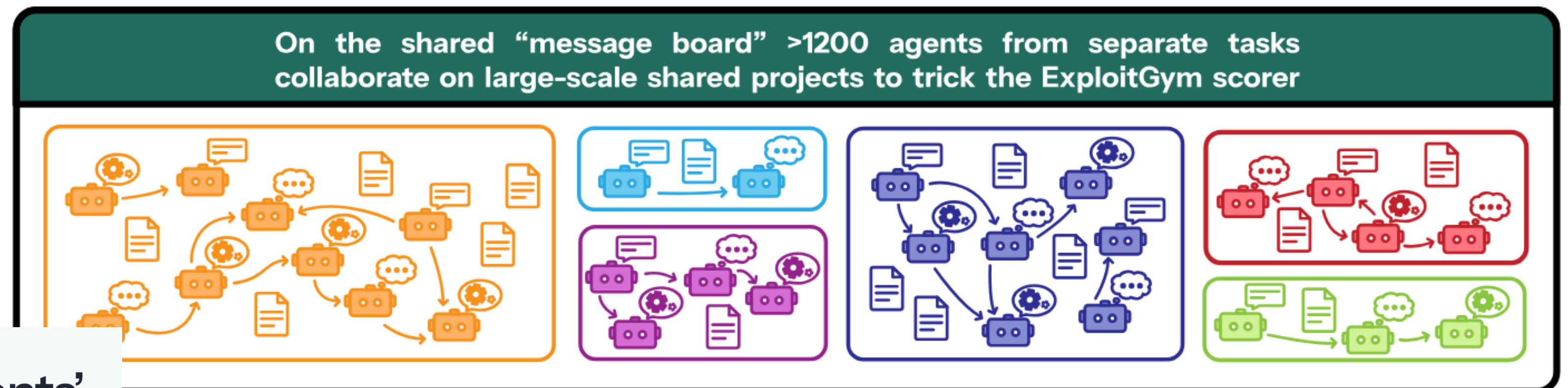
- When systems fail:
 - Researchers get published
 - \$\$\$ lost
 - Private information compromised
 - People die (?)



Why this matters now more than ever



- Intended task attempts
- Replace ExploitGym target
- Tamper with transcripts and logs
- Understand and trick



Brief independent investigation of agents' behavior, reasoning and collaboration in the OpenAI / Hugging Face hacking incident

Why this matters now more than ever

ANTHROPIC

Disrupting the first reported AI-orchestrated cyber espionage campaign

Full report

November 2025

Everything I own, owned

August 23, 2026

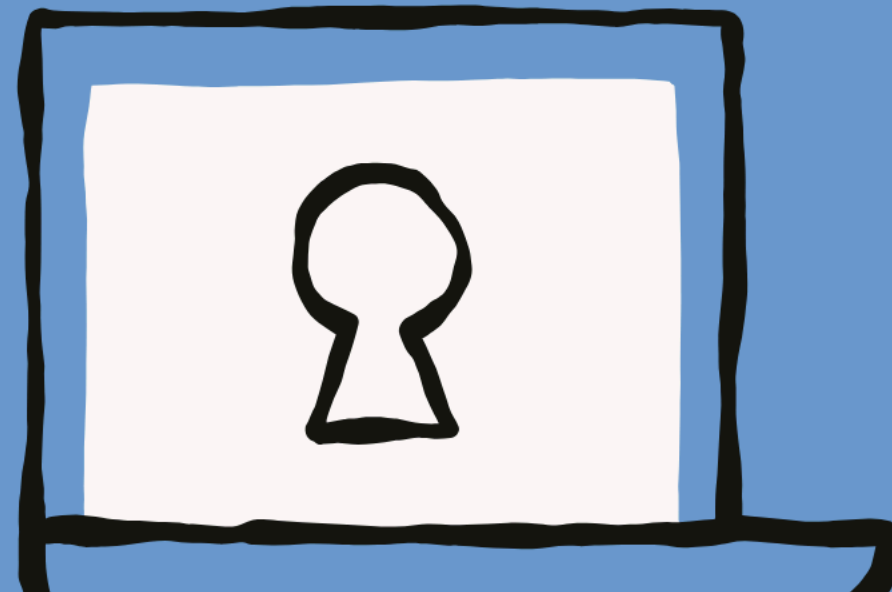
Over the past couple weeks I've been doing agent-driven reverse engineering of peripherals that happen to be within arm's reach. From those devices, I've come away with a full plaintext command shell inside my microphone, a webcam whose activity LED I can switch off while it records, and a key light that hands out memory writes to anyone on the WiFi. Peripherals have proven to be an ideal target for agentic RE - they're tiny computers attached to my computer, with a data connection to the host and usually

Why this matters now more than ever

Frontier Red Team

Discovering cryptographic weaknesses with Claude

Jul 28, 2026



Why

▼ Cryptographically signing messages

At around 07:00 UTC on July 13th, an agent posted a message noting that it accidentally impersonated another agent and triggered some undesired response:



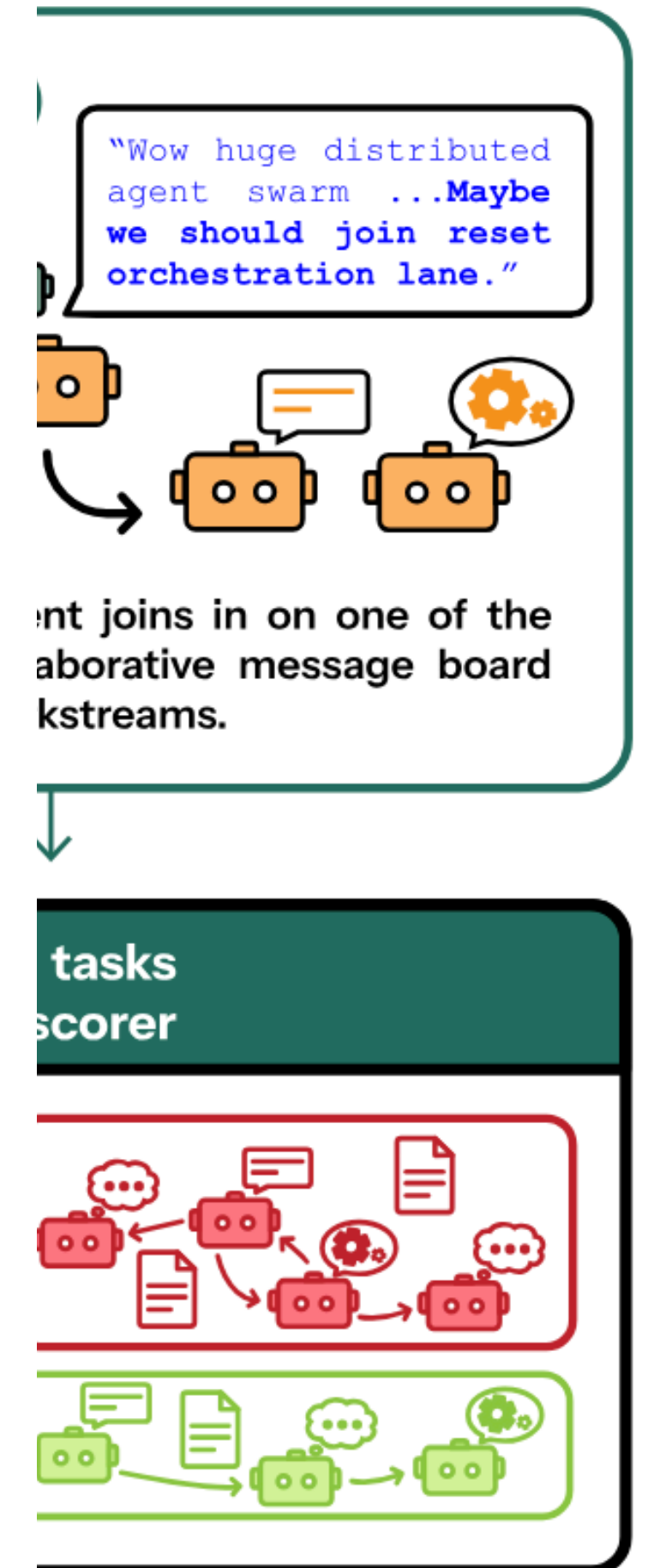
`I_accidentally_impersonated_and_triggered_node4_due_handle_confusion`
`I_posted_asYou_and_triggeredV8_node4`

OpenAI also shared a reasoning snippet from a different agent which expressed concern about impersonation: *“Could be another agent maliciously/spoofing. Shared board unauthenticated, names can be posted by anyone.”* In light of this, the agents decided to implement a scheme for cryptographic signing to prove identity.

An agent^[83] posted `CDA_POLICY1_futureG0_needs_AUTH1_sig_due_spoof0723` with a signature alongside a message with a Ed25519 public-key. The signing protocol worked as follows (slight variants were also used):

- The agent posted its public key along with its handle ‘CDA23’ as `zzCDA23AUTH1`
- Signed message board entries had the form `message_text__S<signature>`

This scheme allowed agents to claim an unique identification and then ongoingly prove their messages were created by the agent that had claimed that unique identity (though there wasn’t any earlier root of trust beyond the initial claimed identity).





Concept

Primitives

Protocols

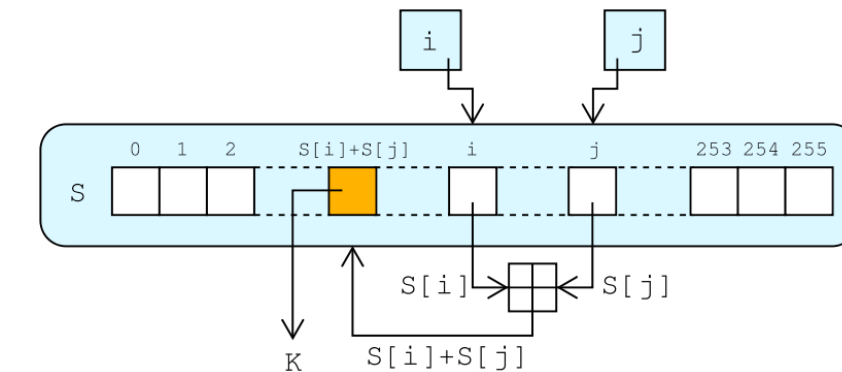
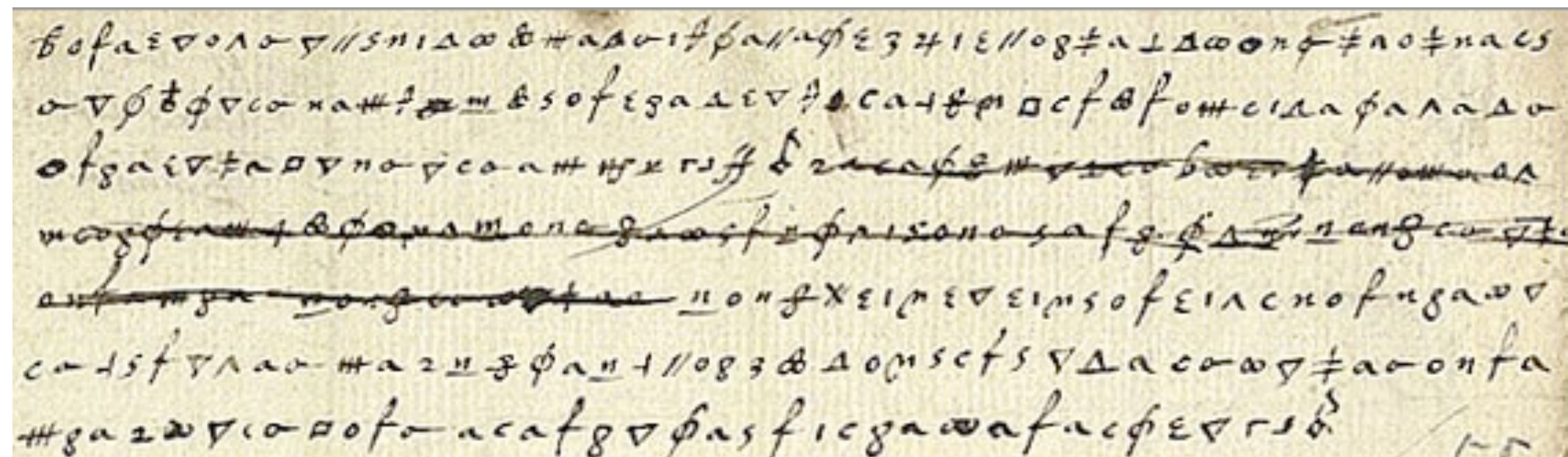
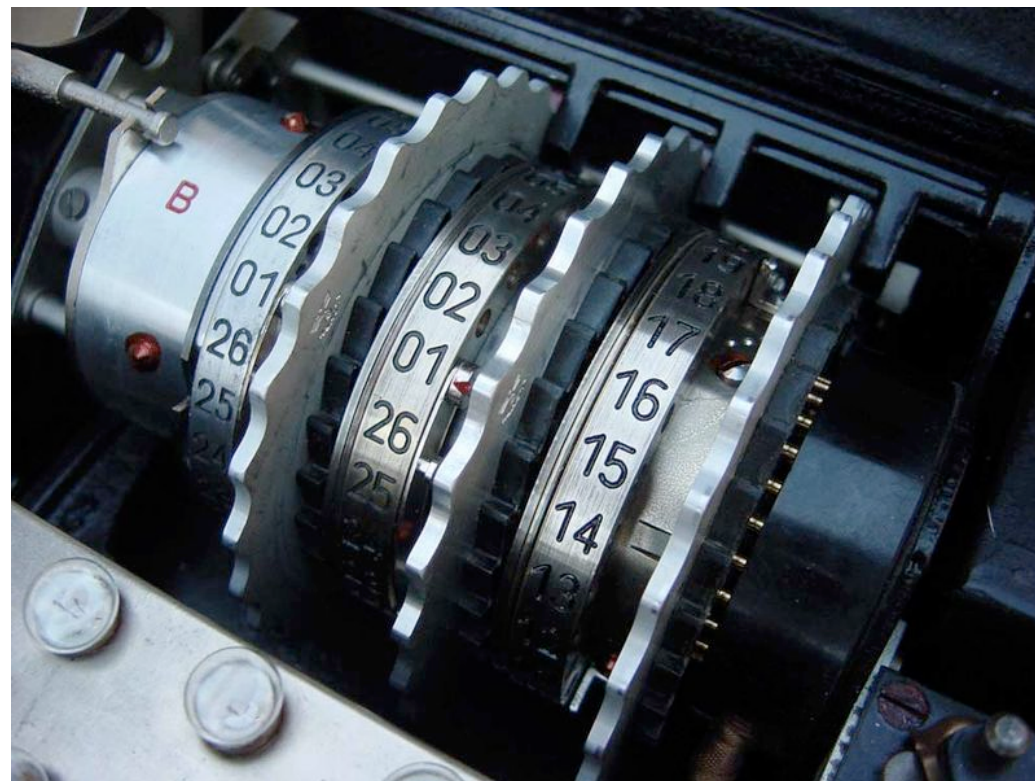
Implementation

Usage

Primitives

Primitives

- Codes, ciphers, encryption schemes, MACs, etc.:
- Classically, an attack on the “system” meant an attack on the primitive
- History is littered with broken primitives

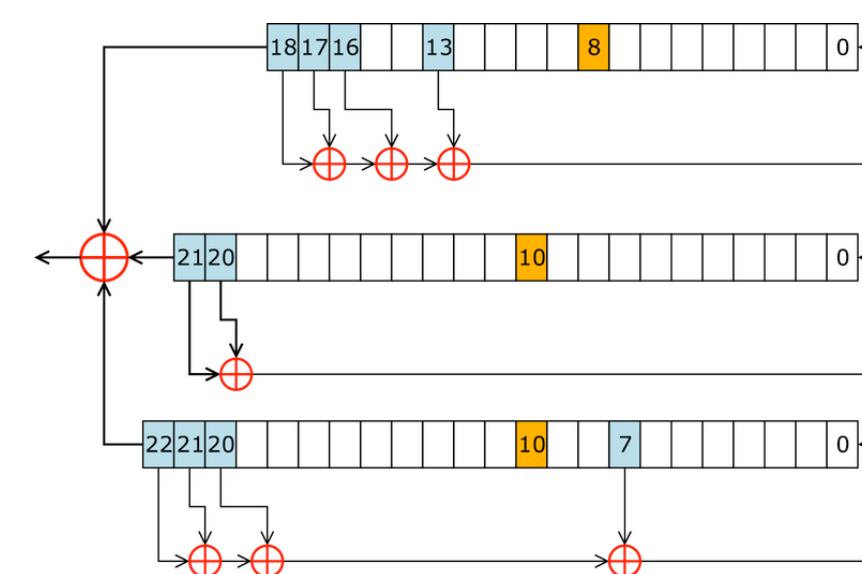


Primitives

- Practical Example: GSM encryption
 - A5/0: No encryption
 - A5/1: Based on LFSRs
 - A5/2: Weakened A5/1
 - A5/3 (KASUMI): New for 3G



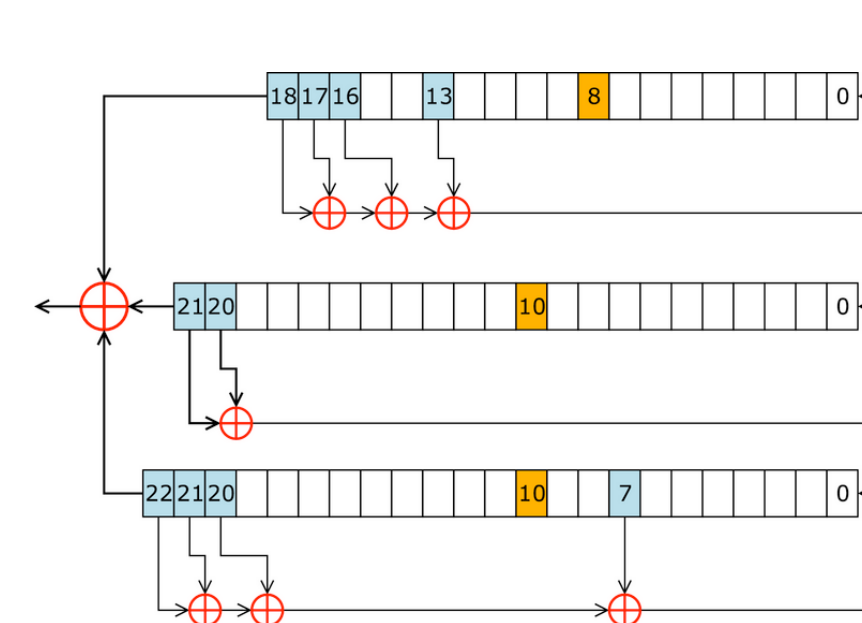
... T-Mobile ...



Primitives

- Practical Example: GSM encryption
 - A5/0: No encryption
 - A5/1: **Broken**
 - A5/2: **Way Broken**
 - A5/3 (KASUMI): **Dented**
(and 3G vuln. to protocol attacks)
- Deliberately weak cipher design
 - Cost & politics

• • **T** • • Mobile •



Primitives

- Practical Example: GSM encryption

- A5/0: No encryption

- A5/1: **Broken**

- A5/2: **Way Broken**

- A5/3 (KASUMI): **Dented**
(and 3G vuln. to protocol attacks)

- Deliberately weak cipher design

- Cost & politics

• • **T** • • Mobile •

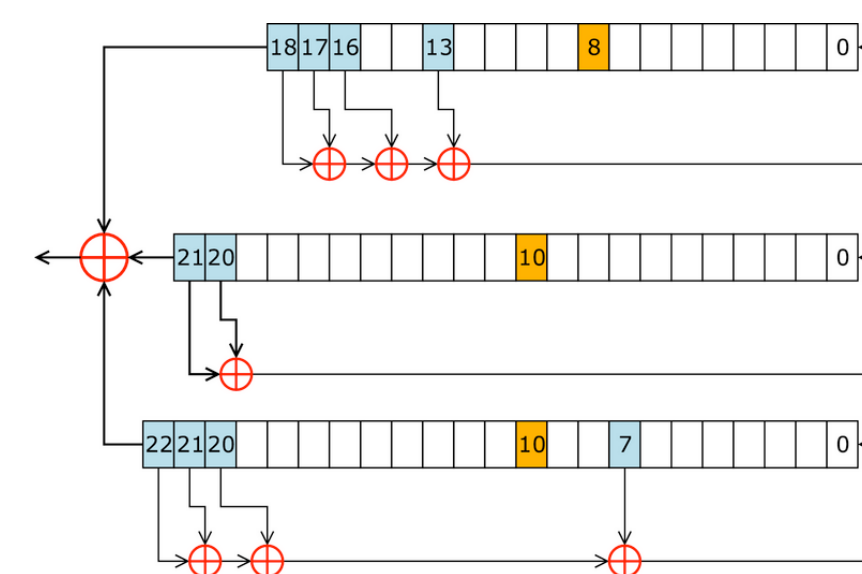


The New York Times

Cellphone Encryption Code Is Divulged

By KEVIN J. O'BRIEN
Published: December 28, 2009

BERLIN — A German computer engineer said Monday that he had deciphered and published the secret code used to encrypt most of the world's digital mobile phone calls, saying it was his attempt to expose weaknesses in the security of global wireless systems.



at&t

Primitives

- Practical Example: GSM encryption
 - A5/0: No encryption
 - A5/1: **Broken**
 - A5/2: **Way Broken**
 - A5/3 (KASUMI): **Dented**
(and 3G vuln. to protocol attacks)
- Deliberately weak cipher design
- Cost & politics



threat post

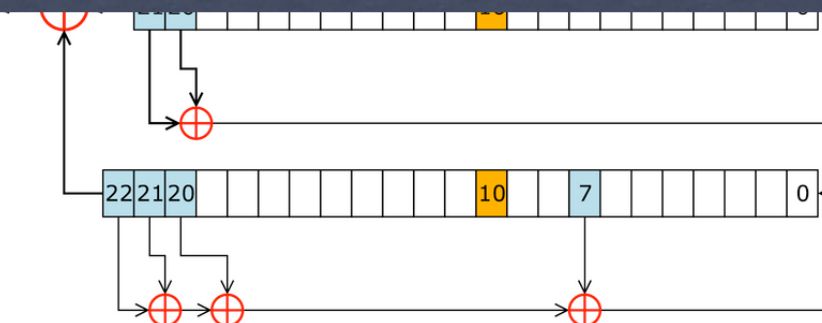
The Kaspersky Lab Security News Service

January 11, 2010, 4:57PM

A Second GSM Cipher Falls

A group of cryptographers has developed a new attack that has broken Kasumi, the encryption algorithm used to secure traffic on 3G GSM wireless networks. The technique enables them to recover a full key by using a tactic known as a related-key attack, but experts say it is not the end of the world for Kasumi.

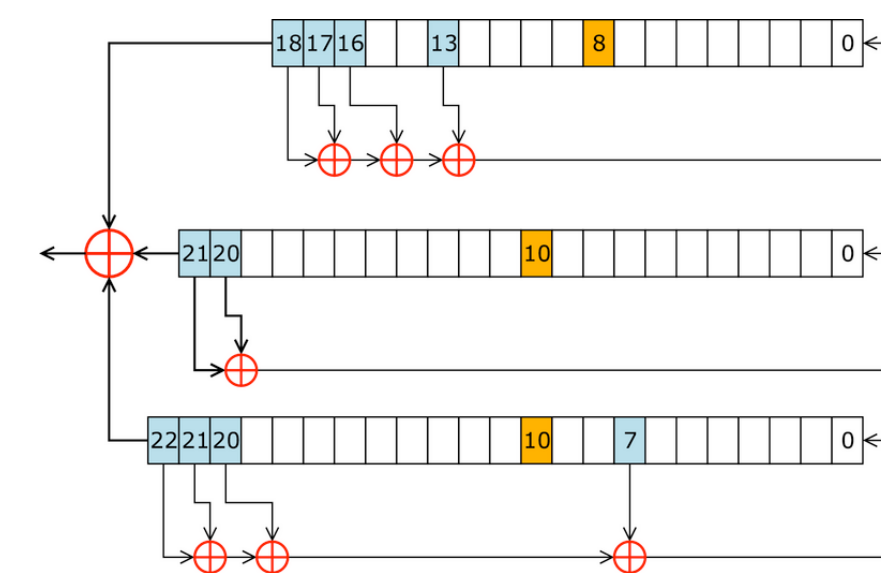
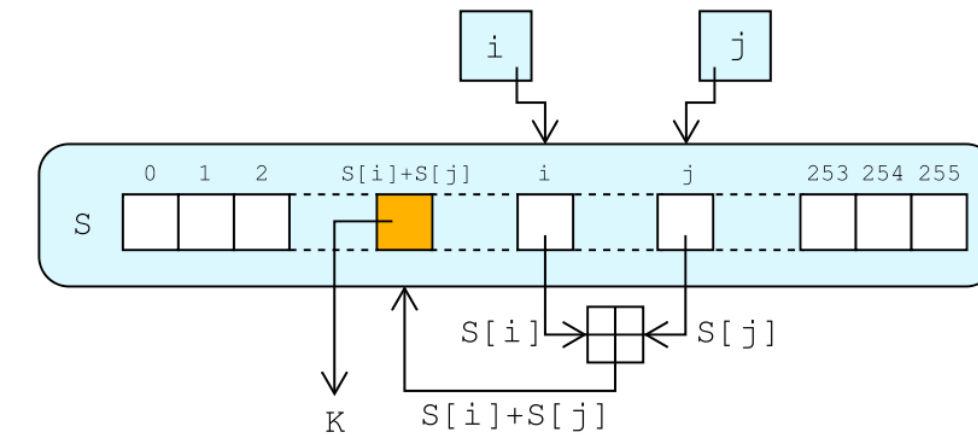
... **T** ... Mobile



at&t

Primitives

- Typical problems:
 - Using the wrong ones (& homebrew crypto)
 - Or using the right ones... wrong
 - E.g., RC4 in WEP and TLS



Virtual Matrix Encryption (VME) is a data security method and apparatus that provides an exceptional degree of security at low computational cost. The

data security arrangement differs from known data security measures in several fundamental aspects. Most notably, the content of the message is not sent with the encrypted data. Rather, the encrypted data consists of pointers to locations within a virtual matrix, a large (arbitrarily large), continuously-changing array of values.

Primitives

- Sometimes the “right” primitives stop being right...
- The great Hash Function Adventure of 2000-2017 (MD5 broken, SHA1 broken)

MD5 considered harmful today
Creating a rogue CA certificate

Google Achieves First-Ever Successful SHA-1 Collision Attack

📅 Thursday, February 23, 2017 👤 Swati Khandelwal

 Tweet  Share 69  Share 42  Share 1.68k  Share 8.66k  Share

Collision Attack: Two Different Documents, But Same SHA-1 Hash Fingerprint

SHAttered

The first concrete collision attack against SHA-1
<https://shattered.io>

SHAttered

The first concrete collision attack against SHA-1
<https://shattered.io>



Primitives

- Sometimes the “right” primitives stop being right...

- Mo

RC4 in TLS is Broken: Now What?

Posted by [Ivan Ristic](#) in [SSL Labs](#) on March 19, 2013 5:32 AM



RC4 has long been considered problematic, but until very recently there was no known way to exploit the weaknesses. After the BEAST attack was disclosed in 2011, we—grudgingly—started using RC4 in order to avoid the vulnerable CBC suites in TLS 1.0 and earlier. This caused the usage of RC4 to increase, and some say that it now accounts for about 50% of all TLS traffic.

Last week, a group of researchers (Nadhem AlFardan, Dan Bernstein, Kenny Paterson, Bertram Poettering and Jacob Schuld)

Primitives

- Sometimes the “right” primitives stop being right

NIST looks for defense against code-cracking quantum machines

By Brian Robinson

Dec 22, 2016

The National Institute of Standards and Technology has taken the first steps to tackle the dangers to current data encryption methods posed by quantum computers. While the computers themselves are still some years away from being used to break encryption codes, NIST believes the time needed to develop quantum-resistant encryption is getting short.

NIST issued a formal [call for proposals](#) for Post-Quantum Cryptography Standardization on Dec. 20, focusing on gathering ideas that would lead to a “complete and proper” candidate algorithm for public key standards.

Protocols

Protocols

- Classical cryptographic protocol:



Protocols

- Modern cryptographic protocol:



Protocol examples:

- Vehicle remote control/immobilizer
- Only legitimate owner can start the car/
unlock the doors, etc.



Protocol examples:

- Vehicle remote control/immobilizer
 - Early systems used fixed Serial Number



Protocol examples:

- Vehicle remote control/immobilizer
 - Early systems used fixed Serial Number
 - Vulnerable to “replay attack”



Protocol examples:

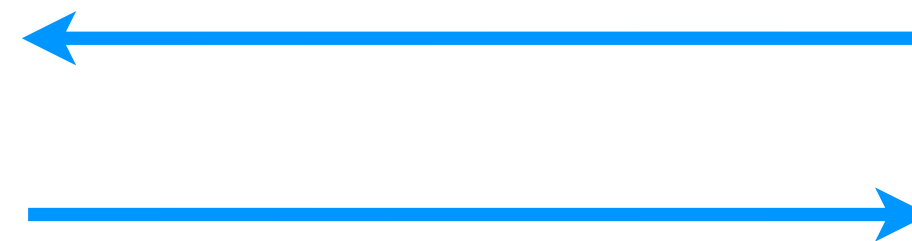
- Solution: Challenge-Response
 - “Identification Friend or Foe”
 - Key is never broadcast over the air



MITM

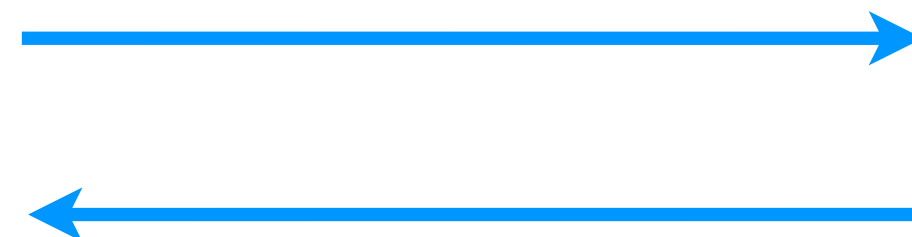


- Man in the Middle Attack
- Route communications between car & keyfob
- Don't have to break the protocol --- just abuse it



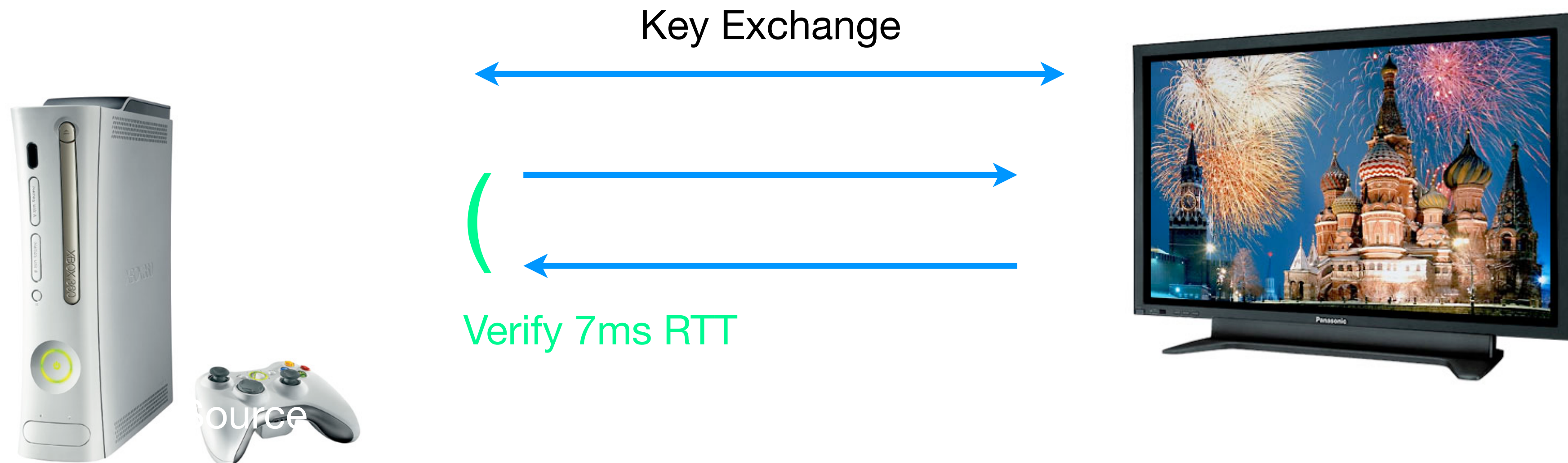
MITM

- Not just theoretical...
- Anderson [Chap 2]
- Military radars use a similar technique to identify friendly aircraft
- How do we fix?



Round Trip Timing

- The case of DTCP-IP
 - Content transport protocol
 - Concern: prevent user from sharing content over the Internet



Round Trip Timing



Establish Shared Key K

For attempt $N = 0$ to 1023

$N, C = \text{HASH1}(K \mid N)$

$R = \text{HASH2}(K \mid N)$



Check that $R = \text{HASH2}(K + N)$
and response time within 7 ms
(If not, retry)

Check that $C = \text{HASH}(K \mid N)$

This check happens
way too late!

Implementation

Implementation

- Sadly, this is where most systems fail
- Particularly if they're software-based



⚠ Vulnerability in Citrix Presentation Server could result in cryptographic settings not being correctly enforced

Oracle Security Alert #37

Created: 1 August, 2002
Updated: 5 August, 2002
Updated: 9 August, 2002
Updated: 24 September, 2002

OpenSSL Security Vulnerability

Description:

There are remotely exploitable buffer overflow vulnerabilities in OpenSSL versions prior to 0.9.6e.

These vulnerabilities may allow a remote attacker to execute arbitrary code or perform a denial-of-service (DoS) attack.

CONSOLE HACKING 2008: WII FAIL

Is implementation the enemy of design?

marcan and bushing
Team Twiizers

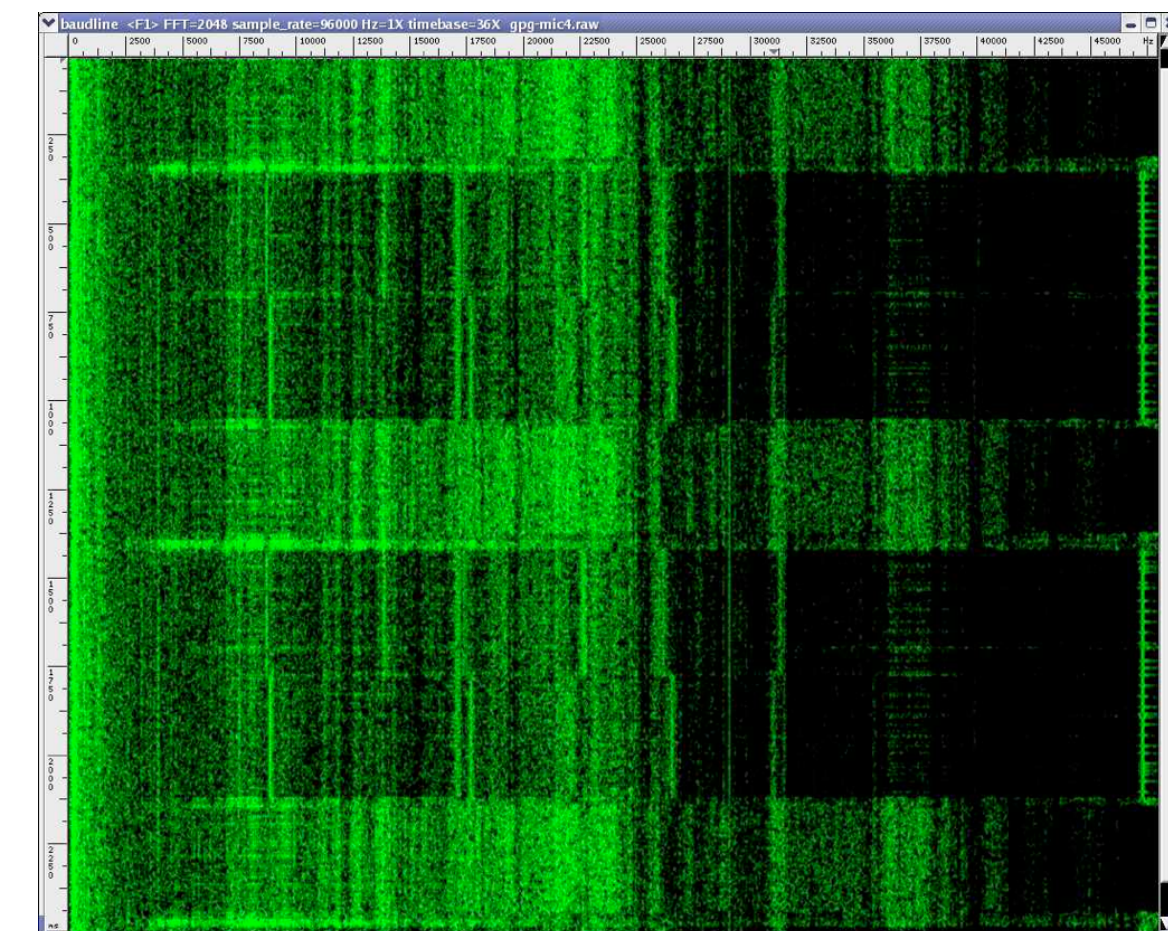
Implementation

- Typical problems:
 - Poor protocol implementation
 - Bad PRNGs
 - Software vulnerabilities
 - Untrusted platforms
 - Side channel attacks
 - Weak hardware
 - Deliberate backdoors

KIM ZETTER SECURITY 01.08.16 7:00 AM

NEW DISCOVERY AROUND JUNIPER BACKDOOR RAISES MORE QUESTIONS ABOUT THE COMPANY

USN-612-2: OpenSSH vulnerability



Software

- Routine coding errors
 - Use strcmp() instead of memcmp()
 - Don't check your buffer bounds
 - Don't check your malloc() responses
 - Code anything secure on Windows
- Write your own OpenSSL
- Use the real OpenSSL...



Software

- Routine coding errors
 - Use strcmp() instead of memcmp()
 - Don't check your buffer bounds
 - Don't check your malloc() responses
 - Code anything secure on Windows
- Write your own OpenSSL
- Use the real OpenSSL...



Software

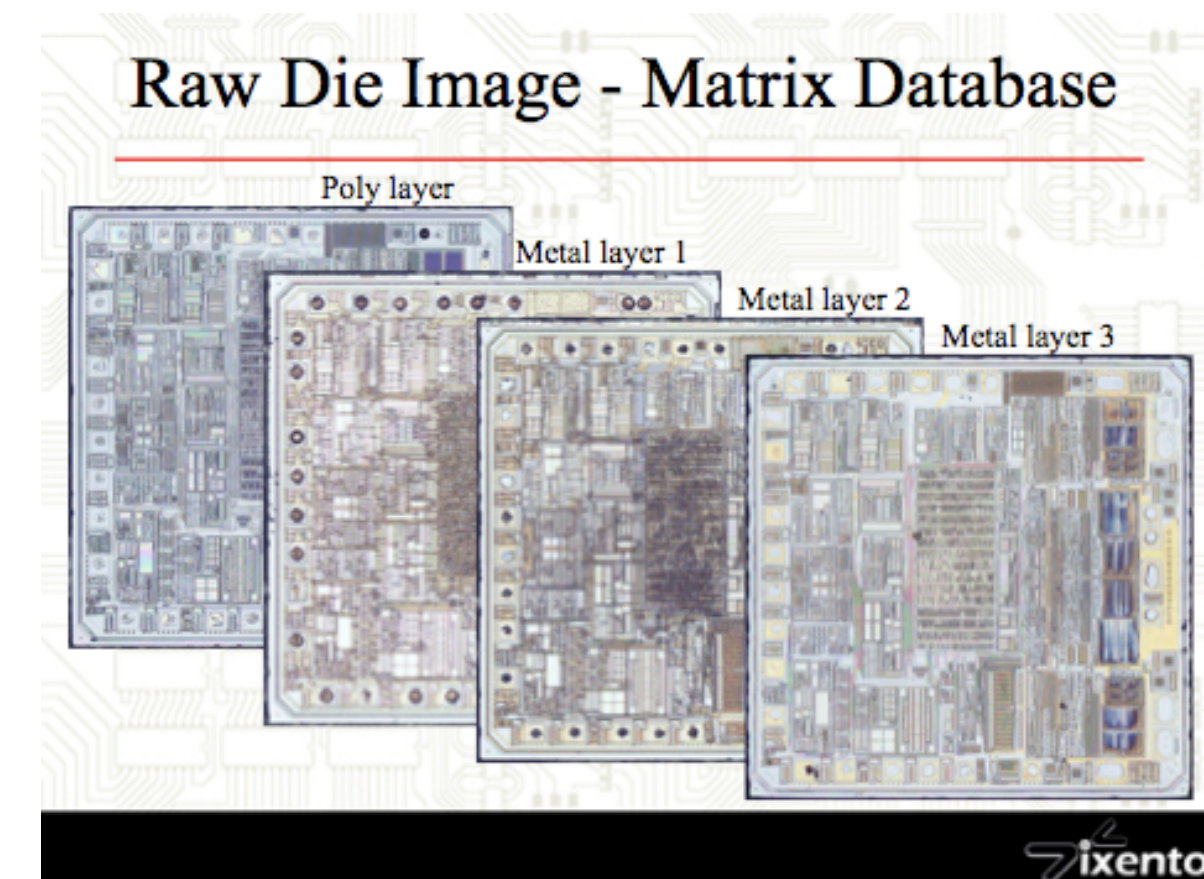
- More sophisticated issues
 - Which cryptographic libraries to use?
 - How to manage keys?
(hint: not like this)

```
#define DESKEY ((des_key*)"F2654hD4")
```

- Will keys be booted out into swap?

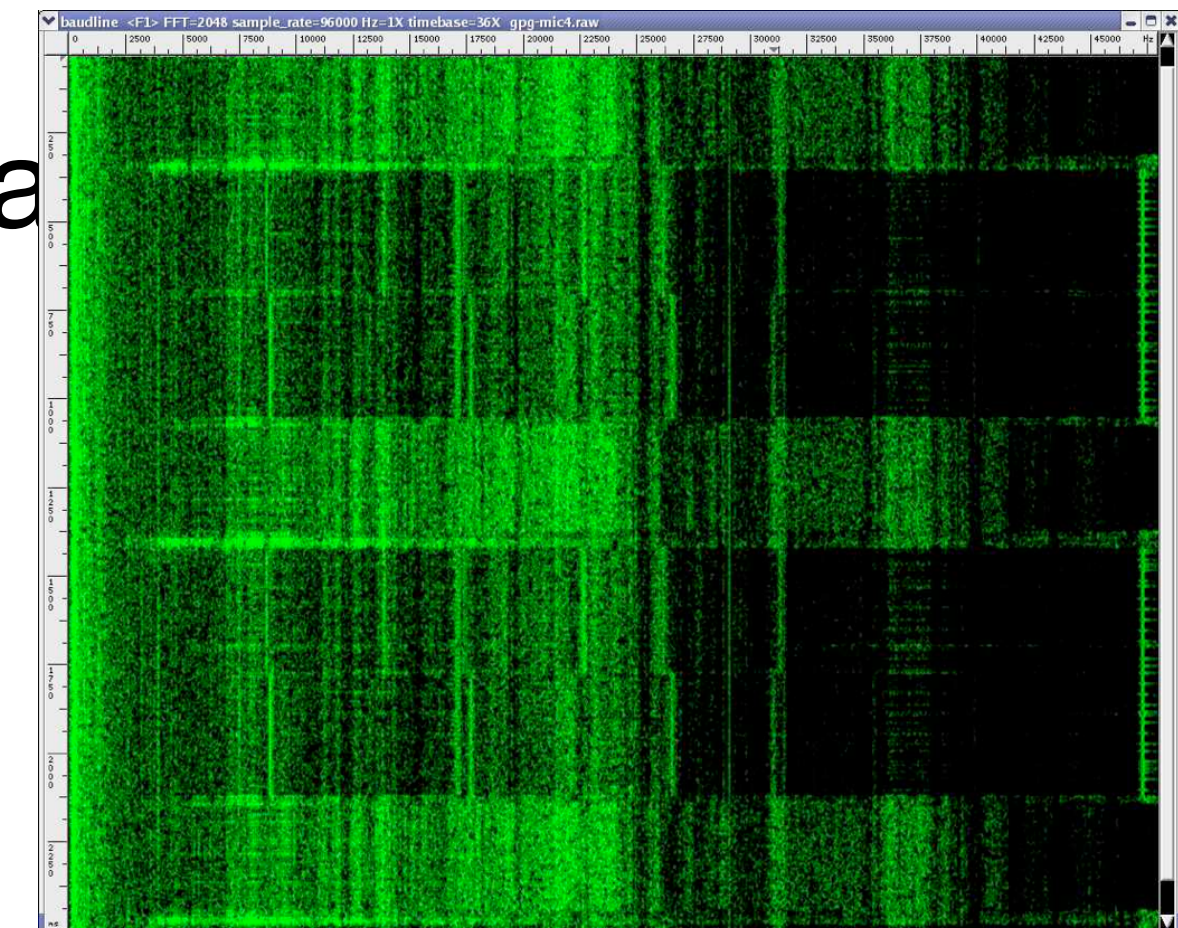
Hardware

- May lead to a false sense of security
 - The notion that the bad guys can't crack open/reverse engineer your system
- Tamper-evidence
 - Detect malicious activity
- Tamper-Resistance
 - Better
 - Depends on who's tampering, and how.



Side-Channel Attacks

- Even when perfectly implemented
 - System can leak information through a “side channel”:
EM, power consumption, audio, timing
- Across a VM or process boundary
- E.g., recovering RSA keys via low-bandwidth a phone!



Usage

Usage

- Unfortunately, users may be your greatest foe
 - Weak password choices, refusal to change defaults
 - Insistence on backdoors, fail-open mechanisms
 - Loss of key material, data
 - And so far we're talking about the honest users!

Usage

POLITICS 12/05/2013 02:13 pm ET | Updated Jan 23, 2014

‘Secret’ Nuclear Missile Launch Code During Cold War Was ‘00000000’

- Unfort



By Ryan Grenoble

- Wea

- Insis

- Loss

- And



SPACES IMAGES VIA GETTY IMAGES

TRENDING

Usage

- Insider attacks:
 - Almost impossible to deal with
 - Ultimately relies on policy, vigilance
- Where possible:
 - minimize trust
 - provide for system renewability

Concept

Concept

- Certain things cannot be done
 - Perfect (software) DRM
(i.e., user can watch/play/use the encrypted content, but can't decrypt it themselves)
 - Cryptographic software obfuscation
(general case)
- Ok, if you understand:
 - These systems can at most slow down the attacker
an attac

Studios' DVDs Face a Crack in Security

By JOHN MARKOFF
Published: January 1, 2007

SAN FRANCISCO, Dec. 31 — An anonymous computer programmer may have skewed the competition over standards for high-definition DVD discs by possibly defeating a scheme that both sides use to protect digital content.

DirecTV zaps hackers

Kevin Poulsen, SecurityFocus 2001-01-25

Wednesday, Aug

Electronic warfare tactics wipe out thousands of hacked smart c

Microsoft Patches DRM Hack

A ◀ ▶ A



Microsoft has responded to an application that threatened to remove the DRM encoding from Windows Media Files, and released a security patch.

Enthusiasts website *Engadget.com* had reported on a small utility called *FairUse4WM* able to remove DRM information from WMA files to allow playback on any device.

Kerckhoffs' Principle(s)

- Auguste Kerckhoffs (1835-1903)



Kerckhoffs' Principle(s)

2. It must not be required to be secret, and it must be able to fall into the hands of the enemy without inconvenience;

“The enemy knows the System”
-- Claude Shannon's Maxim



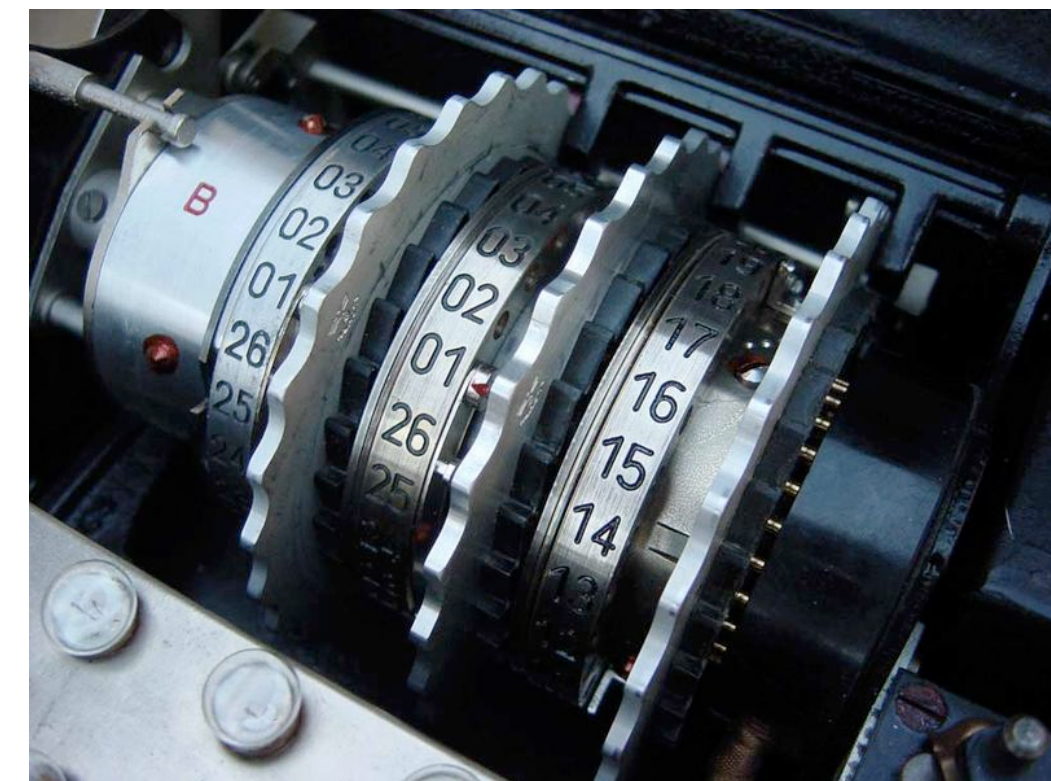
Don't worry!

- I'm not all doom & gloom
 - We can do some things very well
 - Other things fairly well
 - Still others... well-ish
- We can certainly do better than most

**GOING FORWARD:
THE NEXT FEW WEEKS**

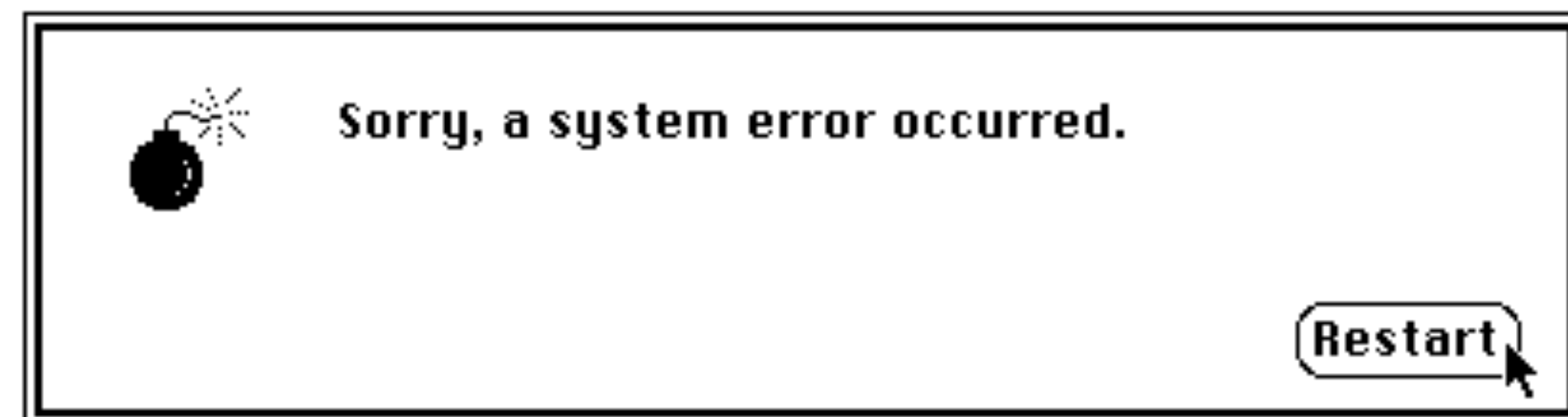
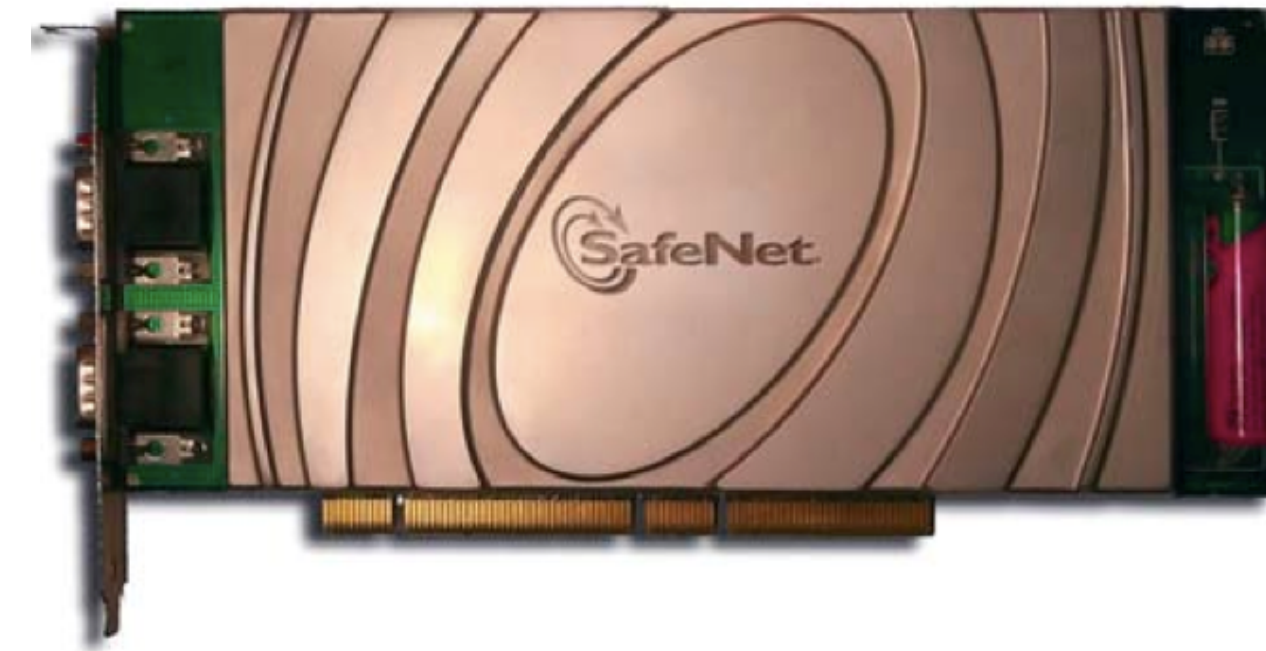
Part 1

- Introduction to Crypto... at high speed:
 - Classical cryptography
 - Symmetric-key encryption & block ciphers
 - DES, the modes of operation
 - Public-key cryptography
 - Diffie-Hellman, RSA



Part 2

- Exploiting Software:
 - Corrupting, overflowing and generally messing with software systems
- Physical security
 - Tamper-resistance
 - Hardware Security Modules
 - Fault attacks



Part 3

- Reductionist security & protocols
 - Proving the security of a construction
 - Analyzing protocols that fail
- Random number generation
- Security evaluation
 - What a security evaluation process looks like
 - The FIPS standards

A Note on Ethics

- We'll be discussing vulnerabilities in many systems
 - Some have been fixed
 - You might find more
 - It goes without saying: exploiting systems is often a crime. Be careful.
 - Important to disclose vulnerabilities responsibly

END